

Análise e Remediação de Vulnerabilidades no Windows Server 2016 com Wazuh e Inteligência Artificial

Caio Adriano

CECYBER - Pós-graduação em Cibersegurança

Disciplina: IA e ML em Cybersecurity

Professor: Eduardo Popovici - Agosto de 2026

Resumo - Este artigo apresenta um laboratório reproduzível de detecção, análise e remediação de vulnerabilidades em um Windows Server 2016 monitorado pelo Wazuh 4.14.7. O ambiente foi executado em máquinas virtuais Oracle VM VirtualBox, com comunicação isolada em rede host-only. Na linha de base, o Wazuh identificou 1.733 registros de vulnerabilidade no servidor, distribuídos em 35 críticos, 1.201 altos, 486 médios e 11 baixos. Para o estudo aprofundado foi selecionada a CVE-2026-56190, classificada com CVSS 3.1 de 9,8 e relacionada à execução remota de código no Remote Desktop Protocol. A inteligência artificial foi empregada para estruturar a triagem, propor verificações não destrutivas e organizar o plano de correção; todas as recomendações foram confrontadas com documentação oficial. A análise confirmou que o serviço RDP não estava exposto no momento do teste, embora o sistema permanecesse vulnerável pela versão instalada. A aplicação da atualização cumulativa KB5120418 elevou a compilação de 14393.0 para 14393.9418. Após a sincronização do agente, o inventário filtrado do Wazuh deixou de apresentar vulnerabilidades ativas para o endpoint analisado. O estudo demonstra um ciclo completo de gestão de vulnerabilidades, com evidências antes e depois da intervenção.

Palavras-chave - Wazuh; gestão de vulnerabilidades; Windows Server 2016; inteligência artificial; CVE; remediação.

I. INTRODUÇÃO

A gestão de vulnerabilidades é um processo contínuo que envolve identificar ativos, localizar falhas conhecidas, priorizar riscos, aplicar medidas corretivas e verificar se a intervenção produziu o resultado esperado. O NIST define a gestão de patches como a identificação, priorização, aquisição, instalação e verificação de atualizações, tratando-a como manutenção preventiva necessária à redução de incidentes e interrupções [1].

Este trabalho aplica esse ciclo em um cenário controlado. Um Windows Server 2016 Standard foi monitorado por uma implantação Wazuh em Ubuntu. O objetivo não foi explorar a falha nem executar código ofensivo, mas demonstrar capacidade técnica de construir o ambiente, interpretar achados, avaliar a exposição real, corrigir o sistema e validar o estado posterior. Essa abordagem produz evidências úteis tanto para avaliação acadêmica quanto para portfólio profissional.

A presença de uma CVE em um scanner não prova, isoladamente, que o ativo esteja explorável. É necessário correlacionar versão, componente, configuração, serviço em execução, exposição de rede e disponibilidade de correção. Por isso, a CVE-2026-56190 foi estudada em profundidade e submetida a verificações locais antes da remediação.

II. FUNDAMENTAÇÃO TÉCNICA

A. Detecção de vulnerabilidades no Wazuh

O Wazuh utiliza o Syscollector para obter inventário de sistema operacional, pacotes e hotfixes. No servidor central, o módulo Vulnerability Detection correlaciona esse inventário com informações de inteligência de ameaças da plataforma Wazuh CTI. Quando a versão de um componente coincide com o intervalo afetado por uma CVE, o item é registrado no inventário de vulnerabilidades [2]. Para produtos Microsoft, a coleta de hotfixes permite ao Wazuh reconhecer correções e atualizar o estado do achado [2].

B. Vulnerabilidade selecionada

A CVE-2026-56190 descreve o uso de recurso não inicializado no Windows Remote Desktop Protocol, possibilitando execução de código por atacante não autenticado através da rede. O vetor CVSS 3.1 é AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H, resultando em pontuação 9,8 e severidade crítica [3]. Esse perfil justifica prioridade elevada, mas a análise de risco precisa verificar se o RDP está habilitado e acessível.

C. Inteligência artificial como apoio

O ChatGPT foi utilizado como ferramenta de apoio à análise, e não como autoridade final. A IA recebeu os dados coletados no Wazuh e foi solicitada a propor hipóteses, comandos de verificação, medidas de contenção e um roteiro de validação. O uso é compatível com a capacidade declarada da ferramenta de analisar informações e imagens fornecidas pelo usuário [4]. Como modelos generativos podem produzir respostas incorretas ou desatualizadas, identificadores, pontuações, compilações e atualizações foram confirmados em fontes oficiais antes da execução.

III. AMBIENTE E PROCEDIMENTO REPRODUZÍVEL

A. Topologia e recursos

O laboratório foi executado em um computador com 32 GB de memória RAM. Para reduzir consumo, as máquinas foram utilizadas por etapas. O Wazuh permaneceu ligado durante a comunicação, a coleta de inventário e as consultas ao dashboard. O Windows Server recebeu temporariamente um segundo adaptador NAT apenas durante o Windows Update; a comunicação entre agente e gerente permaneceu na rede host-only.

TABELA I - COMPONENTES DO LABORATÓRIO

Componente	Configuração	Função	Endereço relevante
Oracle VM VirtualBox	Virtualização local	Hospedagem das VMs	Host físico
Ubuntu + Wazuh	Wazuh 4.14.7, instalação all-in-one	Gerente, indexador e dashboard	192.168.56.105
Windows Server 2016	Standard x64, agente 4.14.7	Endpoint analisado	192.168.56.104
Rede host-only	192.168.56.0/24	Comunicação isolada do laboratório	TCP 1514 para o agente
Adaptador NAT	Temporário no servidor Windows	Acesso ao Windows Update	Removível após a correção

A rede host-only cria uma interface virtual no host e permite comunicação entre host e máquinas virtuais sem conectar diretamente as VMs à rede física [5]. Essa escolha reduziu a exposição do servidor desatualizado. O NAT foi habilitado somente quando necessário para baixar atualizações.

B. Instalação do Wazuh central

Para reprodução em Ubuntu compatível, a documentação oficial permite instalar os três componentes centrais no mesmo host com o assistente all-in-one [6]. O comando deve ser executado com privilégios administrativos:

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
```

Ao final, o assistente informa o endereço HTTPS do dashboard e as credenciais administrativas. No ambiente deste estudo, a interface host-only do gerente utilizou 192.168.56.105.

C. Implantação do agente Windows

No Windows Server 2016, o PowerShell foi aberto como administrador. Como o sistema original possuía componentes

antigos de comunicação segura, o TLS 1.2 foi selecionado para a sessão de download. O instalador recebeu o endereço host-only do gerente e o nome lógico do agente:

```
[Net.ServicePointManager]::SecurityProtocol =
[Net.SecurityProtocolType]::Tls12
Invoke-WebRequest -Uri
https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.7-1.msi
-OutFile $env:TEMP\wazuh-agent.msi
msiexec.exe /i $env:TEMP\wazuh-agent.msi /q
WAZUH_MANAGER='192.168.56.105' WAZUH_AGENT_NAME='LAB-
SRV-2016'
Start-Service WazuhSvc
```

A documentação do Wazuh estabelece que o agente transmite dados ao gerente por canal autenticado e criptografado, e confirma o uso de msiexec com a variável WAZUH_MANAGER para implantação por linha de comando [7]. A conectividade pode ser verificada com Test-NetConnection 192.168.56.105 -Port 1514, enquanto Get-Service WazuhSvc deve retornar o estado Running.

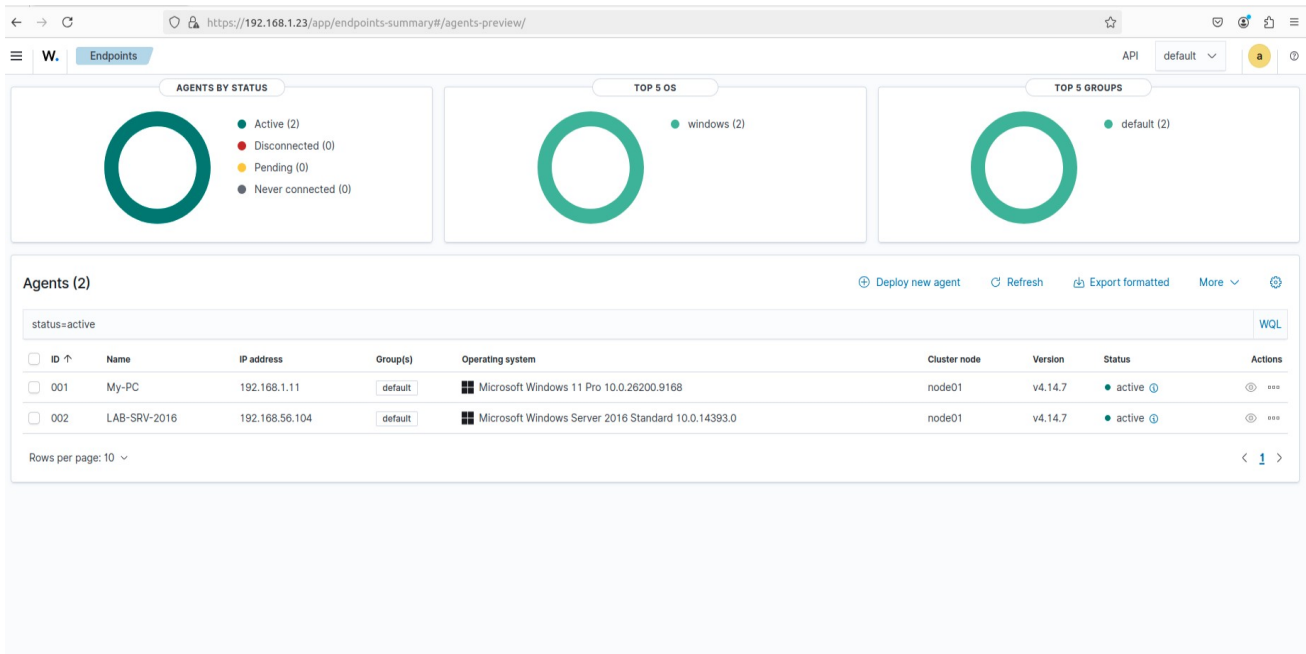


Fig. 1 - Agente LAB-SRV-2016 registrado e ativo no Wazuh antes da análise.

D. Linha de base e coleta inicial

Após a sincronização do inventário, o módulo Vulnerability Detection foi filtrado pelo agente LAB-SRV-2016. A linha de base totalizou 1.733 achados: 35

críticos, 1.201 altos, 486 médios e 11 baixos. Esses valores não representam 1.733 falhas independentes necessariamente exploráveis; são correspondências entre o inventário e os documentos de vulnerabilidade mantidos pelo Wazuh.

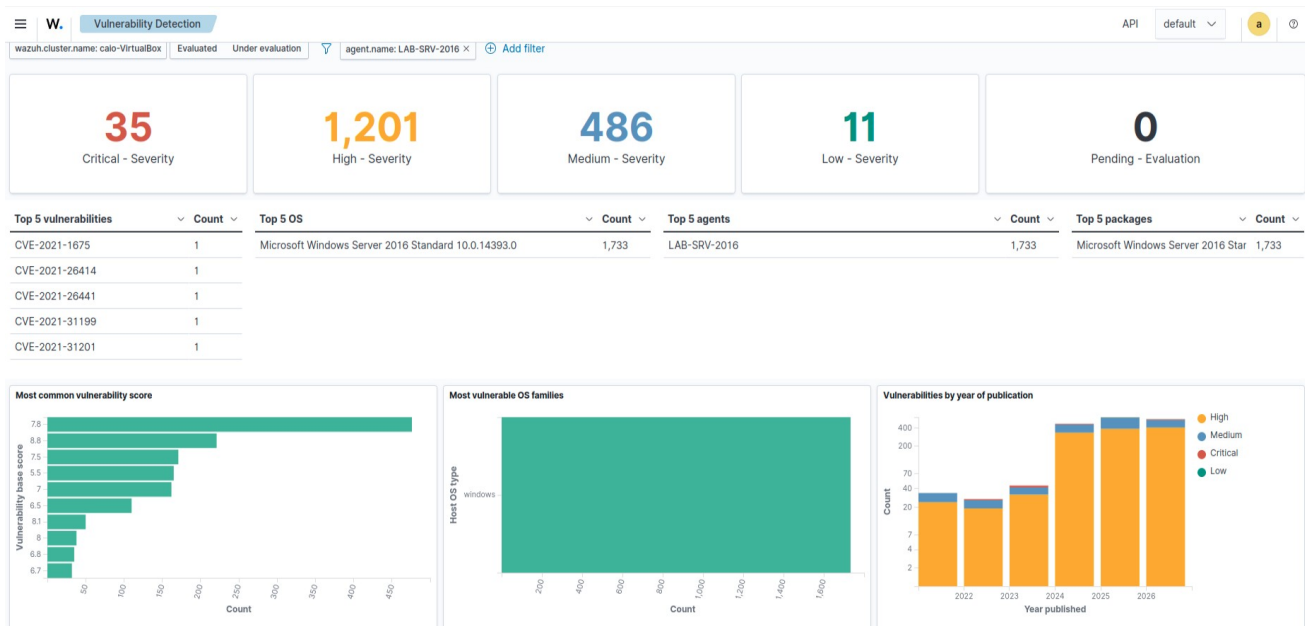


Fig. 2 - Linha de base do Windows Server 2016: 1.733 achados distribuídos por severidade.

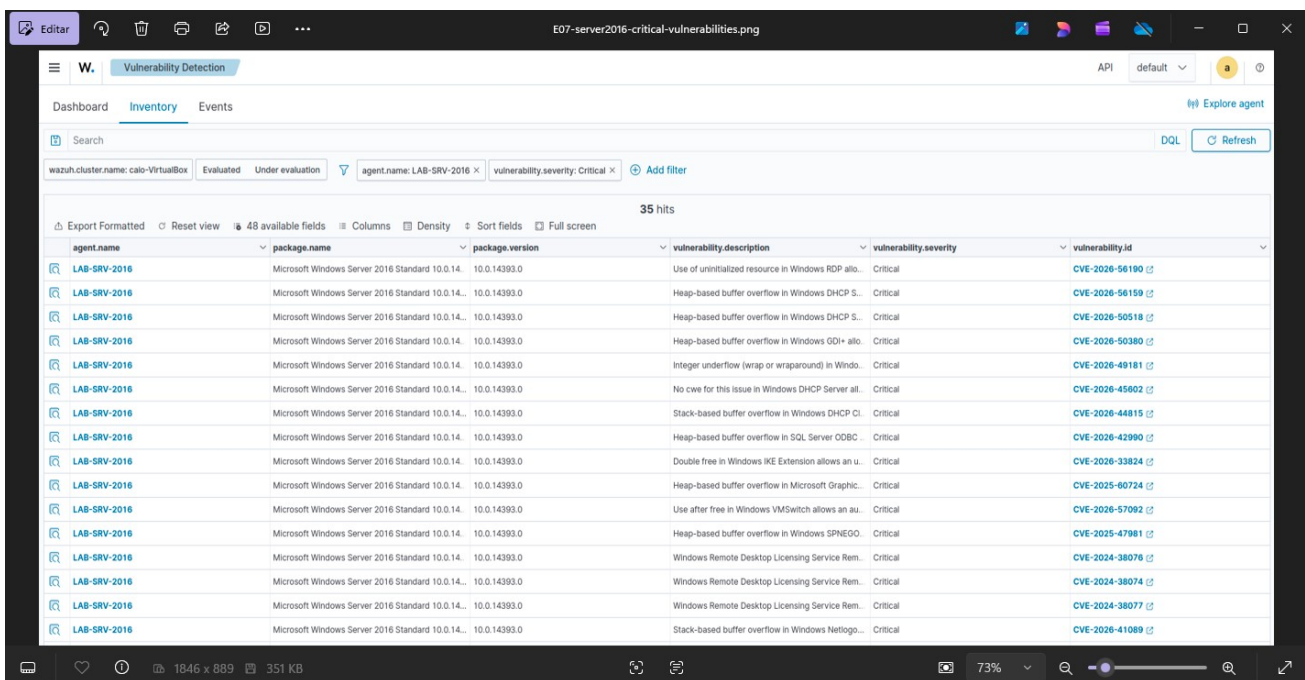


Fig. 3 - Inventário filtrado por severidade crítica, com 35 resultados.

IV. ANÁLISE ASSISTIDA POR INTELIGÊNCIA ARTIFICIAL

A. Prompt empregado

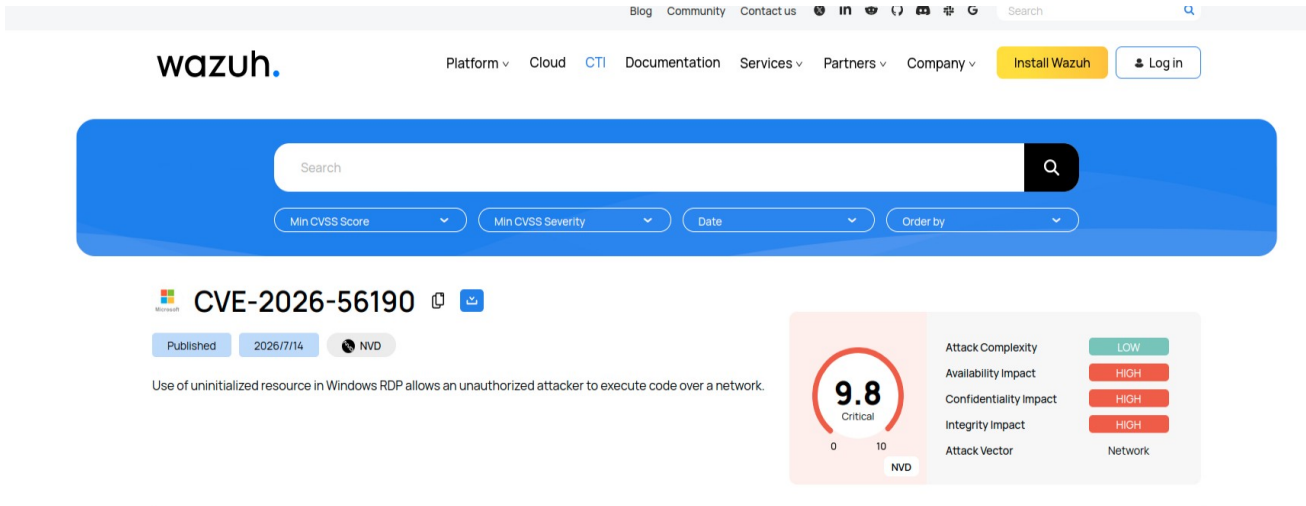
Para tornar o uso da IA auditável, foi adotado um prompt com restrições explícitas. A formulação utilizada foi:

“Atue como analista de vulnerabilidades. Considere Windows Server 2016 Standard, compilação 14393.0, CVE-2026-56190, CVSS 9,8 e componente RDP. Determine condições de exposição, verificações locais não destrutivas, prioridade, mitigação e plano de correção. Não presuma que a presença da CVE equivale à explorabilidade. Indique quais afirmações precisam ser confirmadas em fontes oficiais.”

B. Resultado útil da IA e validação humana

A resposta foi convertida em quatro ações: confirmar a compilação; verificar se o RDP estava habilitado; verificar o serviço TermService e a escuta TCP 3389; e aplicar uma atualização cumulativa seguida de nova coleta no Wazuh. A IA também recomendou manter snapshot anterior à mudança e não executar prova de conceito ofensiva, pois o objetivo era gestão defensiva de vulnerabilidades.

A recomendação foi tecnicamente aceita somente após comparação com NVD, Microsoft Security Response Center, Microsoft Support e documentação do Wazuh. Essa etapa é importante para demonstrar que a IA acelerou a organização da análise, mas a decisão permaneceu sob controle humano.



Affected

Fig. 4 - Detalhes da CVE-2026-56190 no Wazuh CTI: CVSS 9,8, vetor de rede e impactos altos.

V. AVALIAÇÃO DE EXPOSIÇÃO E REMEDIAÇÃO

A. Compilação anterior à correção

A propriedade CurrentBuild confirmou a família 14393 e o UBR igual a 0. Assim, o sistema estava na compilação 10.0.14393.0, coerente com uma instalação sem atualizações cumulativas recentes. O comando usado foi:

```
Get-ItemProperty 'HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion' | Select-Object
ProductName,CurrentBuild,UBR
```

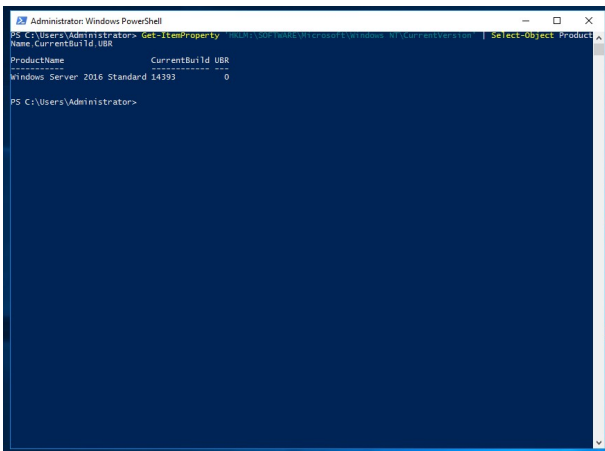


Fig. 5 - Windows Server 2016 na compilação 14393.0 antes da remediação.

B. Verificação da superfície RDP

A chave fDenyTSConnections retornou 1, indicando que conexões remotas estavam desabilitadas. O TermService estava parado, com inicialização manual, e o teste local da porta 3389 retornou TcpTestSucceeded=False. Portanto, o componente vulnerável existia na versão do sistema, mas o vetor RDP não estava exposto durante a coleta. Essa condição reduz o risco imediato, porém não substitui o patch, pois uma alteração futura de configuração poderia reabrir a superfície.

```
Get-ItemProperty 'HKLM:\SYSTEM\CurrentControlSet\Control\Terminal Server' | Select-Object
fDenyTSConnections
Get-Service TermService | Select-Object Name,Status,StartType
Test-NetConnection 127.0.0.1 -Port 3389
```

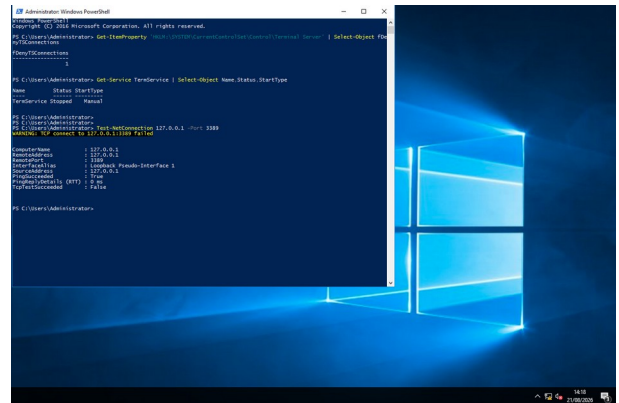


Fig. 6 - RDP desabilitado, TermService parado e porta TCP 3389 sem escuta local.

C. Controle de mudança

Antes da atualização foi criado o snapshot 01-Pre-Remediation-CVE-2026-56190. O snapshot preserva um ponto de retorno do laboratório e registra a disciplina operacional anterior à mudança. Em produção, snapshots não substituem backup testado, mas são úteis em ambientes virtuais de teste.

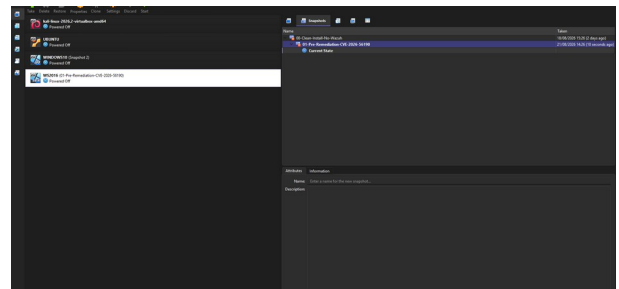


Fig. 7 - Snapshot criado imediatamente antes da remediação.

D. Aplicação da atualização

Um adaptador NAT temporário foi adicionado ao Windows Server para acesso à Internet. O Windows Update ofereceu a KB5120418, atualização cumulativa de agosto de 2026 aplicável ao Windows Server 2016. A Microsoft informa que esse pacote resulta na compilação 14393.9418 e incorpora correções da KB5099535 de julho de 2026 [8]. A atualização foi instalada, o servidor reiniciado quando

solicitado e o ciclo de busca repetido até o sistema informar que estava atualizado.

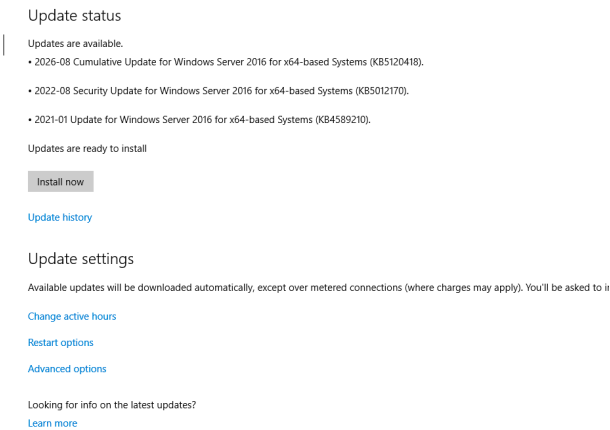


Fig. 8 - KB5120418 disponibilizada pelo Windows Update.



Fig. 9 - Windows Update informando que o servidor estava atualizado após a instalação.

VI. VALIDAÇÃO PÓS-REMEDIAÇÃO

A. Confirmação no endpoint

Após a reinicialização, o mesmo comando de inventário retornou CurrentBuild 14393 e UBR 9418, formando a compilação 10.0.14393.9418. A mudança de UBR de 0 para 9418 constitui evidência objetiva de atualização. A Microsoft associa essa compilação à KB5120418 [8].

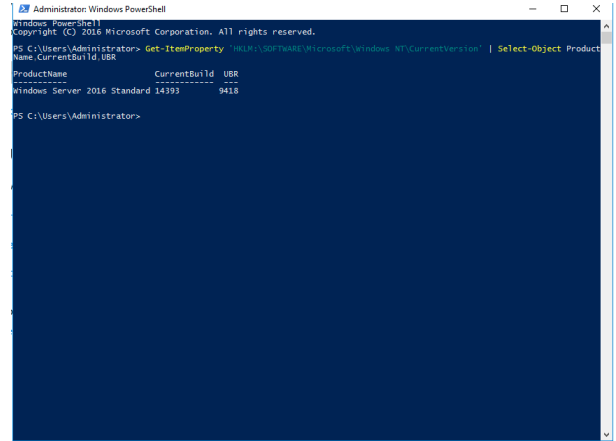


Fig. 10 - Compilação 14393.9418 confirmada depois da atualização.

B. Reconexão e reavaliação pelo Wazuh

O serviço WazuhSvc permaneceu em execução. O arquivo ossec.log registrou conexão com 192.168.56.105:1514/tcp e conclusão de avaliação do Syscollector. No dashboard, o endpoint apareceu ativo e sua versão foi atualizada para 10.0.14393.9418. A alteração do inventário permite ao módulo de vulnerabilidades reavaliar as correspondências de CVE [2].

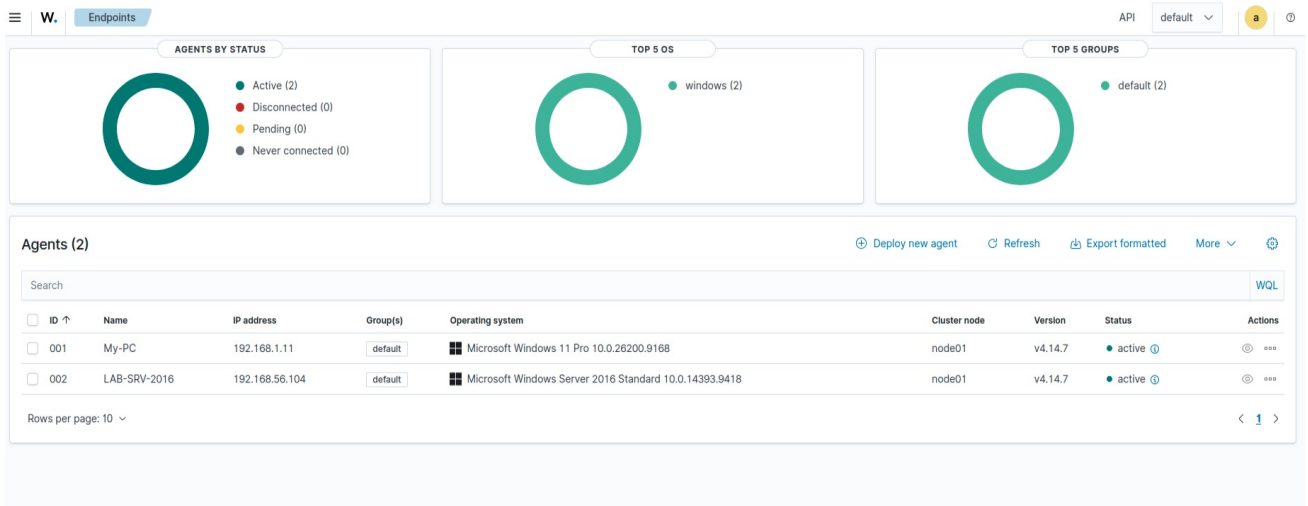


Fig. 11 - Endpoint ativo no Wazuh com a compilação 10.0.14393.9418.

C. Resultado final

Ao abrir Vulnerability Detection para o agente fixado pelo identificador 002, a consulta retornou "No results match your search criteria". No contexto desse filtro, o resultado significa que o inventário não apresentava registros de vulnerabilidade

ativos para o LAB-SRV-2016 no momento da validação. Não se deve generalizar esse resultado como prova permanente de ausência de falhas: novas CVEs, alterações de software, mudanças de configuração ou atualizações do catálogo podem modificar o estado posteriormente.

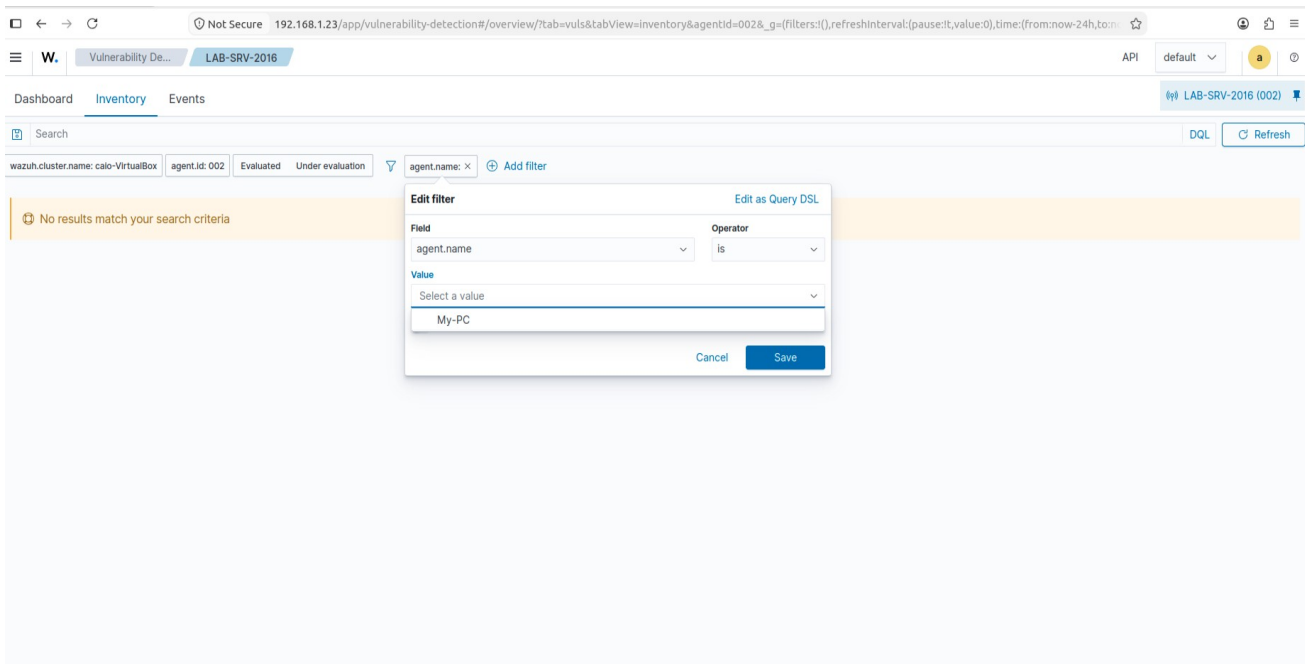


Fig. 12 - Inventário filtrado do agente 002 sem resultados ativos após a remediação.

TABELA II - COMPARAÇÃO ANTES E DEPOIS DA REMEDIAÇÃO

Indicador	Antes	Depois	Interpretação
Compilação do Windows	10.0.14393.0	10.0.14393.9418	Atualização cumulativa aplicada
Achados críticos	35	Sem resultados no filtro do agente	Correspondências ativas removidas após reavaliação
Total de achados	1.733	Sem resultados no filtro do agente	Inventário pós-patch não exibiu itens ativos
Agente Wazuh	Ativo	Ativo	Telemetria preservada durante o ciclo
RDP/3389	Desabilitado e sem escuta	Mantido desabilitado	Controle de exposição complementar ao patch

VII. DISCUSSÃO

O resultado evidencia três competências complementares. A primeira é operacional: construir uma rede virtual isolada, registrar o agente e preservar a comunicação durante alterações de conectividade. A segunda é analítica: separar severidade teórica de exposição real, evitando afirmar que a CVE estava diretamente explorável apenas porque apareceu no scanner. A terceira é de governança: registrar linha de base, criar ponto de retorno, aplicar correção suportada pelo fornecedor e repetir a medição.

A IA agregou valor ao converter dados dispersos em uma sequência de investigação e ao lembrar condições relevantes do RDP. Contudo, ela não substituiu o Wazuh, o NVD ou a Microsoft. A precisão do trabalho dependeu da validação cruzada e das evidências produzidas no próprio ambiente. Esse limite deve ser explícito em qualquer uso profissional de modelos generativos em segurança.

Há limitações. O laboratório analisou um único endpoint e aprofundou uma CVE crítica. Não foram realizados testes de exploração, análise de tráfego ofensivo ou validação externa da porta. Além disso, a ausência de resultados no inventário representa o estado observado e indexado naquele momento,

e não uma garantia absoluta de segurança. Em um ambiente real, o ciclo deve continuar com varreduras recorrentes, gestão de configuração, backups, segmentação, monitoramento e planejamento de migração, pois o suporte estendido do Windows Server 2016 termina em janeiro de 2027 [9].

VIII. CONCLUSÃO

Foi implementado e documentado um ciclo completo de gestão de vulnerabilidades no Windows Server 2016 com Wazuh. A linha de base revelou 1.733 correspondências, das quais 35 eram críticas. A CVE-2026-56190 foi priorizada por severidade e analisada com apoio de inteligência artificial. A verificação mostrou que o RDP não estava habilitado nem escutando na porta 3389, reduzindo a exposição imediata, mas a versão do sistema ainda exigia correção.

A KB5120418 elevou a compilação de 14393.0 para 14393.9418. Depois da sincronização, o Wazuh reconheceu a nova versão e o inventário filtrado não exibiu vulnerabilidades ativas para o agente. O trabalho demonstra que uma boa análise não termina na detecção: ela correlaciona contexto, executa uma mudança controlada e

comprova o resultado com dados independentes do processo de instalação.

DISPONIBILIZAÇÃO DO VÍDEO

Apresentação do laboratório: vídeo em preparação; o link do YouTube será acrescentado após a gravação.

REFERÊNCIAS

- [1] M. Souppaya e K. Scarfone, “Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology,” NIST SP 800-40 Rev. 4, abr. 2022. Disponível em: <https://doi.org/10.6028/NIST.SP.800-40r4>. Acesso em: 23 ago. 2026.
- [2] Wazuh, “How it works - Vulnerability Detection,” Wazuh Documentation, versão 4.14. Disponível em: <https://documentation.wazuh.com/current/user-manual/capabilities/vulnerability-detection/how-it-works.html>. Acesso em: 23 ago. 2026.
- [3] National Institute of Standards and Technology, “CVE-2026-56190 Detail,” National Vulnerability Database, 14 jul. 2026. Disponível em: <https://nvd.nist.gov/vuln/detail/CVE-2026-56190>. Acesso em: 23 ago. 2026.
- [4] OpenAI, “ChatGPT Capabilities Overview,” OpenAI Help Center. Disponível em: <https://help.openai.com/en/articles/9260256-chatgpt-capabilities-overview>. Acesso em: 23 ago. 2026.
- [5] Oracle, “Host-Only Networking,” Oracle VM VirtualBox User Manual, versão 6.1. Disponível em: <https://docs.oracle.com/en/virtualization/virtualbox/6.1/user/networkingdetails.html>. Acesso em: 23 ago. 2026.
- [6] Wazuh, “Quickstart,” Wazuh Documentation, versão 4.14. Disponível em: <https://documentation.wazuh.com/current/quickstart.html>. Acesso em: 23 ago. 2026.
- [7] Wazuh, “Deploying Wazuh agents on Windows endpoints,” Wazuh Documentation, versão 4.14. Disponível em: <https://documentation.wazuh.com/current/installation-guide/wazuh-agent/wazuh-agent-package-windows.html>. Acesso em: 23 ago. 2026.
- [8] Microsoft, “August 11, 2026 - KB5120418 (OS Build 14393.9418),” Microsoft Support, 11 ago. 2026. Disponível em: <https://support.microsoft.com/en-us/servicing/os/windows-10/2026/08/kb5120418-windows-10-1607-security-update>. Acesso em: 23 ago. 2026.
- [9] Microsoft, “Windows Server 2016 - Microsoft Lifecycle,” Microsoft Learn. Disponível em: <https://learn.microsoft.com/en-us/lifecycle/products/windows-server-2016>. Acesso em: 23 ago. 2026.
- [10] Microsoft Security Response Center, “CVE-2026-56190,” Security Update Guide, 14 jul. 2026. Disponível em: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-56190>. Acesso em: 23 ago. 2026.